

# Security Basics & Identity Management

CIA triad, security controls, data protection, logging — then the full identity lifecycle: factors, biometrics, PAM, SSO, and access control models.

## Chapter 1 — Mastering Security Basics DOMAIN 1 FOUNDATION

### The CIA Triad EVERY EXAM QUESTION MAPS BACK TO ONE OF THESE

#### Confidentiality

Only authorized parties can view data.

**Enforced by:** encryption, access controls, steganography.

**Violated by:** data breach, sniffing, shoulder surfing.

#### Integrity

Data hasn't been modified or corrupted.

**Enforced by:** hashing (SHA-256), digital signatures, version control.

**Violated by:** unauthorized change, MITM tampering.

#### Availability

Systems and data are up when needed.

**Enforced by:** redundancy, backups, patching, HVAC, generators.

**Violated by:** DoS/DDoS, ransomware, hardware failure.

#### Confidentiality

encryption · access controls

all three, in balance

#### Integrity

hashing · signatures

#### Availability

redundancy · backups

**The triad is a trade-off.** Pushing one corner affects the others — maximum confidentiality (heavy encryption, strict access) can hurt availability. Exam scenarios ask which corner a control serves.

**Exam cue:** "Verify the file wasn't altered" = **integrity** → **hashing**. "Ensure only HR can read it" = **confidentiality** → **encryption/ACL**. "Keep the site online during attack" = **availability** → **redundancy**. Match the verb to the leg of the triad.

Core risk vocabulary

| TERM              | PRECISE DEFINITION                                                                      |
|-------------------|-----------------------------------------------------------------------------------------|
| Risk              | The <i>likelihood</i> that a threat will exploit a vulnerability, resulting in a loss.  |
| Vulnerability     | A weakness — in software, configuration, or process — that <i>could</i> be exploited.   |
| Threat            | Any circumstance or event with the potential to compromise CIA.                         |
| Security incident | An adverse event that <i>has actually occurred</i> — attack, breach, misuse, data loss. |
| Risk mitigation   | Reducing risk by implementing controls that lower either the likelihood or the impact.  |

Security Controls 4 CATEGORIES × 6 TYPES — CLASSIFY ANY CONTROL TWO WAYS

Categories — *how* the control is implemented

| CATEGORY    | WHAT IT IS                                                       | EXAMPLES                                                             |
|-------------|------------------------------------------------------------------|----------------------------------------------------------------------|
| Technical   | Implemented by technology/systems                                | Firewalls, encryption, IDS, antivirus, least-privilege enforcement   |
| Managerial  | Administrative, documented in policy — focused on risk decisions | Risk assessments, vulnerability assessments, security policies       |
| Operational | Implemented by <i>people</i> in day-to-day work                  | Awareness training, configuration management, media protection       |
| Physical    | You can physically touch it                                      | Locks, fences, guards, bollards, cameras, mantraps/access vestibules |

Types — *when/what* the control does

| TYPE       | GOAL                                                | EXAMPLES                                                       |
|------------|-----------------------------------------------------|----------------------------------------------------------------|
| Preventive | Stop the incident <i>before</i> it happens          | Hardening, account disablement policy, firewall rules          |
| Deterrent  | Discourage the attempt                              | Warning signs, visible cameras, security guards                |
| Detective  | Discover the incident <i>after/while</i> it happens | Log monitoring, SIEM alerts, IDS, motion detectors             |
| Corrective | Restore/reverse after an incident                   | Backups, patching after exploit, IPS blocking an active attack |

| TYPE                                 | GOAL                                              | EXAMPLES                                                         |
|--------------------------------------|---------------------------------------------------|------------------------------------------------------------------|
| Compensating                         | Alternate control when the primary isn't feasible | TOTP app when smart cards can't be deployed yet                  |
| Directive<br><i>directing people</i> | Direct/mandate behavior                           | Policies, standards, AUP, "authorized personnel only" procedures |

**Classic trap:** the same item can land in different types depending on phrasing. A camera *recording* is detective; a visible camera *sign* is deterrent. A backup is corrective; the backup *policy* is directive/managerial. Read which function the question emphasizes.

Control guidance largely comes from **NIST SP 800-series** documents (e.g., SP 800-53 catalogs security and privacy controls for federal systems).

## Protecting Data — PII & Obfuscation Methods

KNOW THE DIFFERENCE BETWEEN THESE FIVE

**PII** (Personally Identifiable Information) = any data that can identify an individual: name + SSN, passport number, biometric records. Drives breach-notification obligations.

| METHOD        | HOW IT WORKS                                                                                          | REVERSIBLE?                 | TYPICAL USE                                      |
|---------------|-------------------------------------------------------------------------------------------------------|-----------------------------|--------------------------------------------------|
| Tokenization  | Replace sensitive value with a non-sensitive <i>token</i> ; real value stored in a secure token vault | Yes, via the vault          | Credit-card processing (PCI DSS scope reduction) |
| Data masking  | Replace characters so only part is visible ( <i>****-****-****-4321</i> )                             | No (display layer)          | Showing partial card/SSN in UIs, test data       |
| Obfuscation   | Make data unclear/ambiguous on purpose (umbrella term)                                                | Sometimes                   | Hiding code logic, generic data hiding           |
| Steganography | Hide data <i>inside another file</i> (image, audio) — hidden, not encrypted                           | Yes, if you know it's there | Covert channels; "security by obscurity"         |
| Hashing       | <u>One-way function</u> producing fixed-length digest                                                 | Never                       | Integrity checks, password storage               |

**Exam cue:** "embedded a message in an image file" = **steganography**. "Replaced card numbers with substitute values for processing" = **tokenization**. "Only last 4 digits visible" = **masking**.

## Key Stretching & Perfect Forward Secrecy TWO CRYPTO CONCEPTS CH 1 PLANTS EARLY

### Key Stretching

Runs a password through thousands of hash iterations + salt so brute-force attacks become computationally expensive.

**Algorithms to know:** `bcrypt` , `PBKDF2` , `Argon2` .

A **salt** (random value added before hashing) defeats rainbow-table attacks.

**Perfect Forward Secrecy (PFS)**

Each session uses a unique *ephemeral* key (Diffie-Hellman Ephemeral — DHE/ECDHE). Compromising the server's long-term private key **cannot decrypt past recorded sessions**.

Required by TLS 1.3 — all its cipher suites are ephemeral.

Logging & SIEM

WHERE EVIDENCE LIVES

| LOG SOURCE      | WHAT IT RECORDS                                                                                                                                                                                                                                        |
|-----------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Security log    | Auditable events: logon success/failure, privilege use, object access (Windows Security log)                                                                                                                                                           |
| System log      | OS events: service start/stop, driver failures, reboots                                                                                                                                                                                                |
| Application log | Events written by individual applications                                                                                                                                                                                                              |
| Linux logs      | <div><div><i>Global</i></div><div><code>/var/log/syslog</code> or <code>/var/log/messages</code> (general), <code>/var/log/auth.log</code> or <code>/var/log/secure</code> (authentication)</div><div><i>System</i></div><div><i>auth.</i></div></div> |
| Firewall logs   | Allowed/blocked connections — source/destination IP, port, protocol                                                                                                                                                                                    |
| Packet captures | Full traffic content via protocol analyzer (Wireshark, <code>tcpdump</code> ); includes <u>payloads + metadata</u> (headers: who, when, where)                                                                                                         |

Syslog & SIEM

*sends to SIEM*

- Syslog** `UDP 514` — standard protocol for shipping log entries to a central collector. Format: facility, severity (0 = Emergency → 7 = Debug), message.
- SIEM** (Security Information and Event Management) — *aggregates* logs from many sources, *correlates* events across them, normalizes time (NTP-synced), alerts in near-real-time, and presents **dashboards**. Long-term archival supports investigations.
- A SIEM is **detective**, not preventive — it surfaces what happened; an analyst or automation responds.

**Exam cue:** "correlate events from multiple servers/devices in one place" = **SIEM**. "Capture and inspect packet contents" = **protocol analyzer / packet capture**.

Resilience & Scaling Vocabulary

PRECISE DEFINITIONS — THESE GET CONFUSED

| TERM               | DEFINITION                                                                                        | DISTINGUISH FROM                   |
|--------------------|---------------------------------------------------------------------------------------------------|------------------------------------|
| Redundancy         | Duplicate components (RAID, failover cluster, dual PSU) so a single failure doesn't take you down | Resiliency (broader goal)          |
| Resiliency         | The system's ability to <i>recover and keep operating</i> after a fault                           | Built <i>using</i> redundancy      |
| Vertical scaling   | Add resources <i>to one node</i> — more CPU/RAM                                                   | "Scale up"                         |
| Horizontal scaling | Add <i>more nodes</i> behind a load balancer                                                      | "Scale out"                        |
| Scalability        | <i>Manual</i> ability to grow to meet demand                                                      | Elasticity is automatic            |
| Elasticity         | <i>Automatic</i> scale up and <b>back down</b> with demand (cloud hallmark)                       | Saves cost vs. static provisioning |

Chapter 2 — Identity & Access Management

WHO ARE YOU, AND WHAT CAN YOU TOUCH

The AAA Framework (+ Identification)

FOUR DISTINCT STEPS — KEEP THEM SEPARATE

| STEP           | QUESTION ANSWERED                    | EXAMPLE                                    |
|----------------|--------------------------------------|--------------------------------------------|
| Identification | "Who do you <i>claim</i> to be?"     | Typing a username                          |
| Authentication | " <i>Prove</i> it."                  | Password + TOTP code                       |
| Authorization  | "What are you <i>allowed</i> to do?" | ACL grants read on the share               |
| Accounting     | "What did you <i>actually do</i> ?"  | Authentication logs, audit trail of access |



Strictly in this order. Each step depends on the previous one — you can't authorize someone who hasn't proven who they are.

**Trap:** a username alone never authenticates — it only identifies. Authorization happens *after* successful authentication, never before.

Authentication Factors & MFA

DIFFERENT FACTORS, NOT TWO OF THE SAME KIND

| FACTOR     | "SOMETHING YOU..."   | EXAMPLES                                                                             |
|------------|----------------------|--------------------------------------------------------------------------------------|
| Knowledge  | know                 | Password, PIN, KBA security questions (weakest factor — answers are researchable)    |
| Possession | have                 | Smart card, security key (FIDO2/passkey), hard token, soft token / authenticator app |
| Inherence  | are                  | Fingerprint, face, iris, vein, gait — biometrics                                     |
| Location   | are <i>somewhere</i> | Geolocation/geofencing as an additional signal                                       |

**MFA rule:** two factors must come from **different categories**. Password + PIN = still single-factor (both knowledge). Password + authenticator code = true 2FA (know + have).

Password policy mechanics

- **Password expiration** — forces periodic change; modern guidance (NIST 800-63B) de-emphasizes routine expiration in favor of length + breach screening.
- **Password history** — remembers previous N passwords so users can't recycle them (pair with minimum age, or users cycle through instantly).
- **Account lockout policy** — *threshold* (e.g., 5 wrong attempts) triggers lock for a *duration* (e.g., 30 min). Defeats online brute-force; doesn't help against offline cracking of stolen hashes.
- **Password manager / vault** — enables long unique passwords per site; the practical fix for password reuse.

HOTP vs TOTP ONE LETTER, ONE KEY DIFFERENCE

HOTP — HMAC-based One-Time Password

Counter-based. Code stays valid **until used** — no expiration. Counter increments on each use.  
Risk: an unused code can be phished and replayed later.

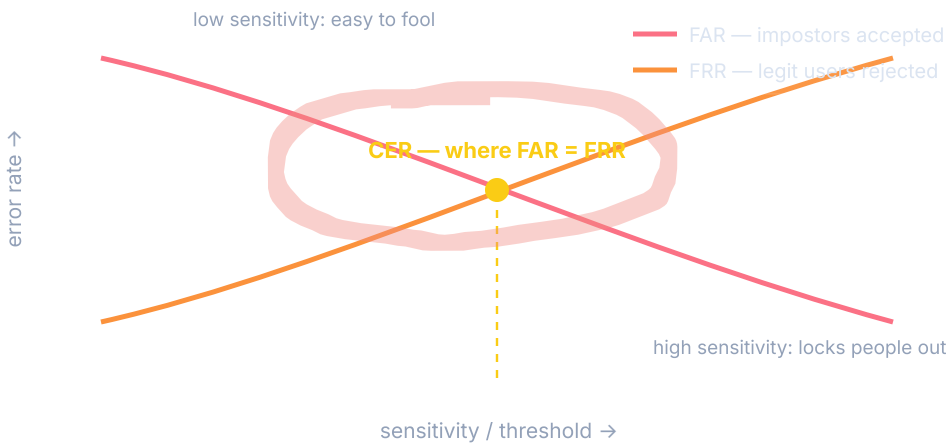
TOTP — Time-based One-Time Password

Time-based. Code expires automatically, typically every **30 seconds**. What Google Authenticator / Microsoft Authenticator use.  
Requires reasonably synced clocks.

**Exam cue:** "the code expired before the user typed it" = **TOTP**. "code remains valid until used" = **HOTP**.  
Hard token = dedicated device; soft token = app on your phone.

Biometric Error Rates FAR VS FRR VS CER — GUARANTEED EXAM FODDER

| METRIC                           | MEANING                                                   | SECURITY IMPACT                                                                 |
|----------------------------------|-----------------------------------------------------------|---------------------------------------------------------------------------------|
| FAR — False Acceptance Rate      | System accepts an <b>impostor</b>                         | Security failure — unauthorized person gets in                                  |
| FRR — False Rejection Rate       | System rejects a <b>legitimate</b> user                   | Usability failure — locked-out employees, helpdesk load                         |
| True acceptance / true rejection | Correct accept of legit user / correct reject of impostor | The desired outcomes                                                            |
| CER — Crossover Error Rate       | The point where FAR = FRR                                 | <b>Lower CER = more accurate system.</b> Use CER to compare biometric products. |



**The crossover point.** Tightening the system slides you right (FAR drops, FRR climbs); loosening slides left. A **lower CER** means the whole system is more accurate — that's the number to compare between products.

**Tuning trade-off:** increase sensitivity → FRR rises, FAR falls (more secure, more annoying). Decrease sensitivity → FAR rises (less secure). The exam loves asking which direction to tune for a "high-security facility" (accept higher FRR).

## Account Lifecycle PROVISION → AUDIT → DEPROVISION

- **Identity proofing** — verifying a person is who they claim *before* issuing credentials (e.g., ID documents at onboarding, verified questions before a password reset).
- **Provisioning** — *creating the account* and granting the access the role needs (and nothing more).
- **Account types** — user, privileged/admin (separate from daily-driver account), service accounts (no interactive login), guest, shared (avoid — destroys accountability).
- **Account audits / attestation** — periodic review where a manager formally confirms each user still needs their access. Primary tool for catching **privilege creep**.
- **Deprovisioning / offboarding** — *disable the account at termination* (don't delete immediately — preserves encrypted data access and audit trail), revoke tokens/keys, recover assets.



- **Time-based logins** — restrict login hours (e.g., no 3 a.m. logins for day-shift staff). **Concurrent session limits** — flag the same account logged in from two places.

**Terminated-employee question:** the BEST first step is **disable the account** (and do it during the exit interview for involuntary terminations) — not delete, not "change the password."

## Privileged Access Management & Least Privilege

ADMIN RIGHTS ARE THE CROWN JEWELS

### PAM — Privileged Access Management

Vaulting, monitoring, and controlling admin credentials. Features: credential check-out, session recording, automatic password rotation.

**Just-in-Time (JIT) permissions:** admin rights granted only when needed, for a limited window, then automatically revoked. No standing privileges.

### Least Privilege & Privilege Creep

**Least privilege:** grant only the access required to do the job — applies to users, processes, and service accounts.

**Privilege creep:** access accumulating as people change roles without old rights being removed. Detected by account audits/attestation; prevented by role-based provisioning.

## SSO, Federation & the Protocols WHO VOUCHES FOR YOU, AND HOW

**SSO** — authenticate once, access many systems. Fewer passwords, but the account becomes a single point of compromise → protect it with MFA.

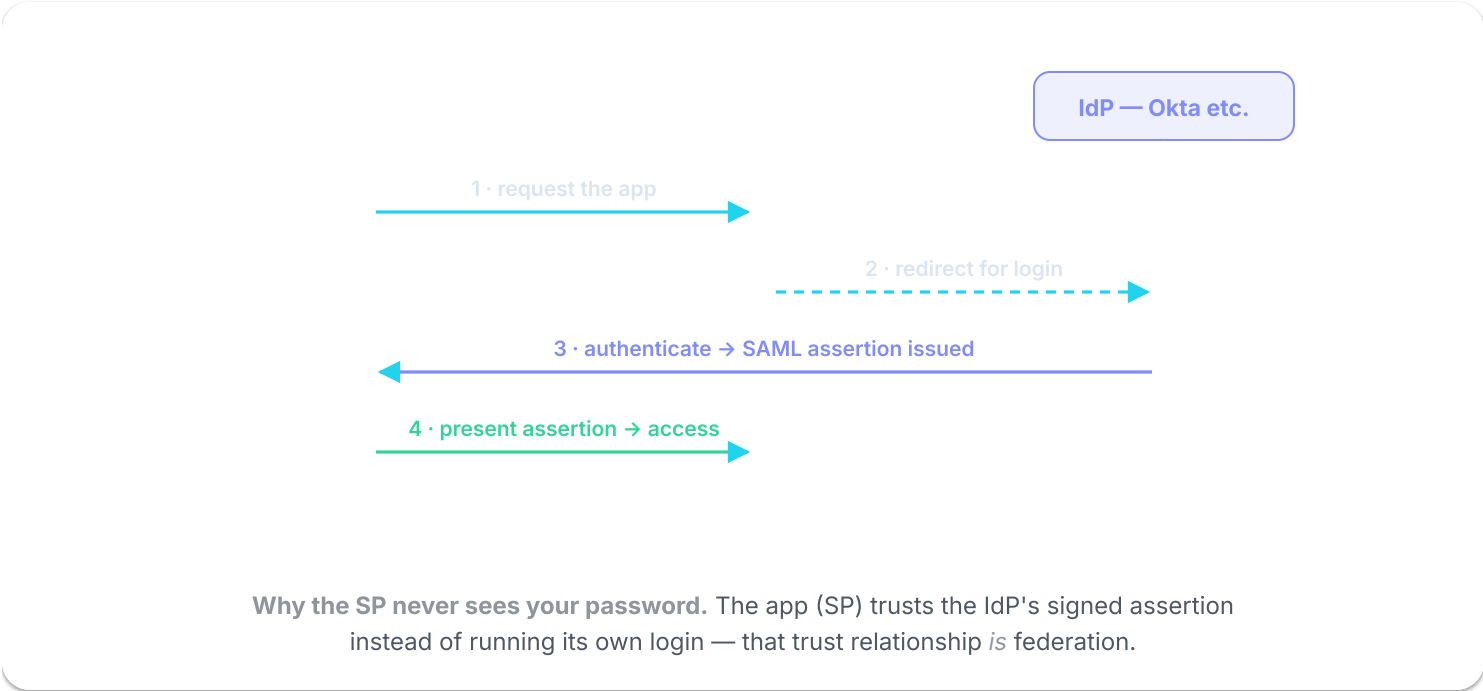
**Federation** — SSO *across organizations* that trust each other. Three parties:

| ROLE                    | FUNCTION                                                                          |
|-------------------------|-----------------------------------------------------------------------------------|
| Principal               | The user trying to access a resource                                              |
| Identity Provider (IdP) | Authenticates the user and issues assertions (e.g., your company's Entra ID/Okta) |
| Service Provider (SP)   | The app/resource that trusts the IdP's assertion instead of doing its own login   |

| PROTOCOL  | PURPOSE                                             | KEY DETAIL                                                                           |
|-----------|-----------------------------------------------------|--------------------------------------------------------------------------------------|
| SAML      | Authentication (and authorization data) for web SSO | XML -based assertions between IdP and SP                                             |
| OAuth 2.0 | Authorization — delegated access                    | "Let app A read my data in app B" without sharing the password; issues access tokens |



| PROTOCOL                           | PURPOSE                                                                 | KEY DETAIL                                                              |
|------------------------------------|-------------------------------------------------------------------------|-------------------------------------------------------------------------|
| <b>LDAP</b> 389 / <b>LDAPS</b> 636 | Directory protocol — query/modify directory services (Active Directory) | X.500-style distinguished names:<br>CN=Jared,OU=Students,DC=sjsu,DC=edu |



**Memory hook:** SAML = authentication ("who you are"), OAuth = authorization ("what an app may do on your behalf"). "Log in with Google" on a third-party site = federation in action.

The Five Access Control Models

IDENTIFY THE MODEL FROM ONE SENTENCE OF SCENARIO

| MODEL                         | ACCESS DECIDED BY                                                                            | TELLTALE EXAM PHRASE                                                                                                   |
|-------------------------------|----------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------|
| <b>RBAC — Role-Based</b>      | Job role / group membership (often hierarchy-based: senior roles inherit junior permissions) | "Permissions assigned to the Sales group, roles & permissions matrix"                                                  |
| <b>Rule-Based</b>             | System-wide rules applied to everyone                                                        | Firewall ACL rules, time-of-day restrictions, "triggered rule changes the setting"                                     |
| <b>DAC — Discretionary</b>    | The resource <b>owner</b> decides                                                            | NTFS permissions — every object has an owner; owner edits the ACL (made of ACEs); Windows tracks identity via SIDs     |
| <b>MAC — Mandatory</b>        | System-enforced <b>labels</b> + clearances; neither owner nor user can override              | Top Secret / Secret labels, military, <b>SELinux</b>                                                                   |
| <b>ABAC — Attribute-Based</b> | Policies evaluating <b>attributes</b> of subject, object, action, environment                | "Allow managers in Finance to access payroll from corporate devices during business hours" — many <i>if</i> conditions |

**Disambiguation:** RBAC = *role*; rule-based = *same rules for all*; DAC = *owner's discretion*; MAC = *labels, no*

Indicators of Anomalous Account Activity

SY0-701 LOVES THESE DETECTION SCENARIOS

| INDICATOR                    | WHAT IT LOOKS LIKE / MEANS                                                                                                             |
|------------------------------|----------------------------------------------------------------------------------------------------------------------------------------|
| Impossible travel            | Login from New York at 9:00, from Moscow at 9:30 — physically impossible → credential compromise. Detected by geolocation correlation. |
| Account lockout spikes       | Many failed attempts across accounts → password spraying or brute force.                                                               |
| Blocked content attempts     | User/process repeatedly hitting blocked sites or denied resources → policy violation or malware beaconing.                             |
| Resource consumption anomaly | Sudden CPU/RAM/disk/bandwidth spike → cryptomining, exfiltration, or compromise.                                                       |
| Resource inaccessibility     | Files suddenly unreadable → possible ransomware encryption in progress.                                                                |
| Log anomalies                | Gaps in logs, cleared event logs, or out-of-pattern entries → attacker covering tracks.                                                |